

Contents

1 セキュリティ設計書 (運営者)	1
1.1 1. 文書概要	1
1.1.1 1.1 目的	1
1.1.2 1.2 対象範囲	1
1.1.3 1.3 版数	1
1.1.4 1.4 関連ドキュメント	2
1.2 2. セキュリティ基本方針	2
1.2.1 2.1 保護対象 (運営者側固有)	2
1.2.2 2.2 想定脅威 (運営者側固有)	2
1.2.3 2.3 基本対策方針	2
1.3 3. データ保護 (運営者側固有)	2
1.4 4. 入力値検証	3
1.5 5. Web 脆弱性対策	3
1.5.1 5.1 CSP / Web セキュリティヘッダ (運営者側)	3
1.5.2 5.2 4-eyes 承認画面の CSRF	3
1.6 6. アクセス制御	3
1.7 7. 監査・ログ (本書の中核、共有概念正本)	3
1.7.1 7.1 ハッシュチェーン構造 (§ 7.3 から移管)	3
1.7.2 7.2 3 区分保持の物理実装 (§ 7.4 / D-08、共有概念正本)	4
1.7.3 7.3 物理削除パッチ	5
1.7.4 7.4 tombstone 方式	5
1.7.5 7.5 監査対象操作の網羅範囲	5
1.7.6 7.6 監査ログエクスポート (§ 10.5)	5
1.8 8. 秘密情報管理 (運営者側固有)	5
1.9 9. SaaS 特有のセキュリティ観点 (運営者側固有)	5
1.10 10. 法令対応 (§ 1.5 から移管)	6
1.10.1 10.1 GDPR 越境移転規制への運用ガード (§ 1.5.1)	6
1.11 11. 不正利用検知 (運営者側固有)	6
1.12 12. 監視 (運用統合)	6
1.13 13. 脆弱性対応 SLA・SCA・ペネトレーション (§ 10.10)	6
1.14 14. ウィジェット保護 / PII マスキング / プロンプト注入対策	7
1.15 15. Webhook 比較除外フィールド (付録 H、D-06)	7
1.16 16. バックアップ・復旧	7
1.17 17. 未決事項	8
1.18 18. 変更履歴	8

1 セキュリティ設計書 (運営者)

1.1 1. 文書概要

1.1.1 1.1 目的

運営者システムのセキュリティ対策を一元化する。**監査ログのハッシュチェーン構造と 3 区分保持 (1y / 5y / 7y) が本書の正本** (共有概念)。**accounts_retired** 永久保持、GDPR 越境移転対応、運営者側固有の不正利用検知 / アクセス制御 / Webhook 一次受信のセキュリティ要件を扱う。

1.1.2 1.2 対象範囲

- 対象: 運営者側セキュリティ全般、メイン側からも参照される **監査ログハッシュチェーン構造・3 区分保持 (共有概念正本)**
- 対象外: PII 暗号化 / オーナー派生 / 暗号 管理 (マスター) (メイン側 [10_セキュリティ設計書.md § 3 / § 8](#) を参照)

1.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
共有概念対応表	監査ログ / / PII の正本所在	../共有/共有概念.md
認証・認可設計書	6 段認可 / 4-eyes / MFA / IP allowlist	09_ 認証認可設計書.md
権限設計書	4-eyes 対象 10 操作	05_ 権限設計書.md
テーブル定義書	audit_logs / webhook_events / accounts_retired	04_ テーブル定義書.md
課金・請求設計書	請求書 7 年保持 / 電子帳簿保存法	11_ 課金請求設計書.md
メイン側 セキュリティ設計書	PII 暗号化 / 管理 (正本)	../01_メインシステム/個別設計書群/10_セキュリティ設計書.md

1.2 2. セキュリティ基本方針

1.2.1 2.1 保護対象 (運営者側固有)

- 運営者の認証情報 (パスワード / MFA シークレット / 回復コード)
- 監査ログ (改ざん検知必須、ハッシュチェーン)
- 削除済み契約のスラグ (**accounts_retired**、永久保持)
- 4-eyes 申請のペイロード (改ざん検知必須)
- Webhook ペイロード (差分検出による改ざん検知)

1.2.2 2.2 想定脅威 (運営者側固有)

- 運営者の内部不正 (高権限の濫用)
- 監査ログの改ざん・削除
- 4-eyes 承認の迂回 (申請ペイロードの差し替え / 自己承認)
- Webhook ペイロードの差し替え (Stripe 連携)
- 法令違反 (GDPR 越境移転、電子帳簿保存法、APPI 等)

1.2.3 2.3 基本対策方針

- **多段ガード** (IP allowlist + MFA + 再認証 + 4-eyes + 監査ログ + ハードゲート KV)
- **改ざん検知** (ハッシュチェーン監査 + payload_hash)
- **永久保持** (**accounts_retired** / **billing_invoices** 7 年)
- **法令対応** (APPI / GDPR / 国税通則法 / 電子帳簿保存法 / 改正電気通信事業法 / 特定電子メール法)

1.3 3. データ保護 (運営者側固有)

メイン側 [10_セキュリティ設計書.md §3](#) を正本とする。本書では運営者側固有のみ:

対象データ	保護レベル	保存時の対策	通信時の対策	ログ出力可否
運営者パスワード	最高	Argon2id(運営者強化プロファイル m=128MB, t=4, p=4, salt=16B)	TLS 1.2+	不可
MFA シークレット	最高	AES-256-GCM(オーナー派生 相当)	TLS 1.2+	不可
MFA 回復コード	最高	Argon2id ハッシュ	TLS 1.2+	不可
4-eyes 申請ペイロード	高	payload_hash(SHA-256) による改ざん検知	TLS 1.2+	監査ログには含む (秘匿情報はマスキング)
Stripe Webhook ペイロード	高	webhook_events に原文保存 + SHA-256 差分検出	TLS 1.2+ + Stripe 署名検証	監査ログ用に保存

1.4 4. 入力値検証

対象	検証内容	対策する脅威
API リクエスト	Zod スキーマ + ticket_id 形式検証	入力エラー / 型混乱
4-eyes 申請ペイロード	JSON Schema + サイズ上限	DoS / インジェクション
Stripe Webhook	署名検証 (Stripe-Signature ヘッダ)	改ざん / リプレイ
お知らせ本文 (SCR-094)	入稿時 + 表示時の 2 重サニタイズ (NFR-309)	XSS

1.5 5. Web 脆弱性対策

メイン側 [10_セキュリティ設計書.md §5](#) を踏襲。運営者側固有:

1.5.1 5.1 CSP / Web セキュリティヘッダ (運営者側)

Content-Security-Policy:

```
default-src 'self';
script-src 'self' 'wasm-unsafe-eval';
style-src 'self' 'unsafe-inline';
img-src 'self' data:;
connect-src 'self' https://app.open-faq.example.com;
frame-ancestors 'none';
form-action 'self';
base-uri 'self';
upgrade-insecure-requests
```

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

X-Content-Type-Options: nosniff

X-Frame-Options: DENY

Referrer-Policy: strict-origin-when-cross-origin

Permissions-Policy: camera=(), microphone=(), geolocation=()

利用者側 Cookie とは Domain スコープを分離、CORS も完全閉 (Access-Control-Allow-Origin: https://admin.open-faq.example.com 固定)。

1.5.2 5.2 4-eyes 承認画面の CSRF

- Double Submit Cookie + payload_hash 二重検証
- ログイン失敗ロックアウト: 5 回失敗で 15 分

1.6 6. アクセス制御

対象	制御方法	関連設計書
運営者画面	IP allowlist + MFA + 6 段認可判定	09_ 認証認可設計書.md
4-eyes 対象 API	6 段認可 + KV ハードゲート	09_ 認証認可設計書.md §7
監査ログ参照	全運営者参照可	本書 §7
Webhook	mTLS + JWT + Stripe 署名	03_API 設計書.md §3.5

1.7 7. 監査・ログ (本書の中核、共有概念正本)

1.7.1 7.1 ハッシュチェーン構造 (§7.3 から移管)

1.7.1.1 テーブルスキーマ (audit_logs)

列名	型	説明
id	TEXT(UUID)	レコード ID
prev_hash	TEXT(hex)	前レコードの record_hash(初行は固定値 0x00...)
record_hash	TEXT(hex)	'SHA-256(prev_hash
actor_id	TEXT	操作者 ID(service_operators.id / users.id / system)

列名	型	説明
actor_type	TEXT	service_operator / admin / end_user / system
action	TEXT	<resource>.<verb> 形式
target_id	TEXT	操作対象 ID
target_type	TEXT	操作対象種別
contract_owner_user_id	TEXT	影響契約 (運営者横断操作は NULL 可、メイン側 contract_owners.user_id を参照)
before_value	JSON	操作前の値 (差分のみ)
after_value	JSON	操作後の値 (差分のみ)
ip_masked	TEXT	IPv4 末オクテット 0、IPv6 末 80 ビット 0
ticket_id	TEXT	対応チケット ID (FR-231)
occurred_at	TIMESTAMP	発生時刻
retention_class	TEXT	1y / 5y / 7y (NFR-602 と整合)

1.7.1.2 ハッシュチェーン計算式

`record_hash = SHA-256(prev_hash || canonical_json(他全フィールド))`

- `canonical_json` 仕様: **JCS (JSON Canonicalization Scheme, RFC 8785)** 準拠、キーをコードポイント昇順ソート、Unicode NFC 正規化、数値 ES6 ToString 規則、null/true/false リテラル維持、文字列内 Unicode はサロゲートペア保持し空白除去
- Webhook ペイロード差分用は本仕様 + EXCLUDE_FIELDS (§ 9 付録 H) 引数差のみ

1.7.1.3 鍵管理

- 単一 (Cloudflare Secret Store、年次ローテーション、**60 日 dual-decrypt**)
- HKDF info 値: `info=audit-export` / `info=mfa-setup` / `info=re-auth` / `info=internal-api`

1.7.1.4 検証バッチ

- 日次バッチ `AuditChainVerifierWorker` (02:00 JST 起動)
- **全件再計算** (直近 90 日窓ではなく全件)
- 不一致検出時: 運営者 `inbox(system/high)+ メール + 検証実行ログ` を `audit_logs(action='audit.chain.verify.fail', retention_class='5y')` に記録

1.7.1.5 IP マスク (NFR-306)

種類	元 IP	マスク後
IPv4	203.0.113.42	203.0.113.0
IPv6	2001:db8:1234:5678:9abc:def0:1234:5678	2001:db8:1234:5678:0:0:0:0

1.7.2 7.2 3 区分保持の物理実装 (§7.4 / D-08、共有概念正本)

区分	retention	期間	対象 action コード
業務監査 (a)	1y	1 年 (NFR-602a)	faq.create、faq.update、chat.reply、account.login、inbox.read 等利用者側操作
運営者高権限 (b)	5y	5 年 (NFR-602d)	owner.suspend、owner.restore、owner.physical_delete、ai_parameter.update、rate_limit.override、budget_limit.override、announcement.send、operator.invite、operator.disable、webhook.replay、prod.direct_change、audit.export、pii_rule.update、webhook.payload_diff.*
課金・取引 (c)	7y	7 年 (NFR-602b、電子帳簿保存法・国税通則法)	billing.invoice.issued、billing.credit_note.issued、billing.cron.run、stripe.event.processed

値の正本表記: `audit_logs.retention_class` の値は **クラス名表記** (`general` / `billing` / `operator_high_priv`) を正本とする。期間表記 (`1y` / `5y` / `7y`) はクラス名から導出できる人間可読補助。詳細は [04_テーブル定義書.md § 2.1](#) を参照。

1.7.3 7.3 物理削除バッチ

- 日次 03:00 JST 起動 (Cron Triggers)
- `DELETE FROM audit_logs WHERE retention_class='1y' AND occurred_at < now() - 365d`
- 5y / 7y も同様
- 削除前に R2 へ圧縮アーカイブ (法令対応エビデンス保管、年次)

1.7.4 7.4 tombstone 方式

- 保持期間経過後の削除および退会確定時: 本文 (actor / target / IP / payload) を物理削除しつつ、`id / prev_hash / current_hash / deleted_at` を保持
- tombstone 自体は監査ログの保持期間を超えても削除しない (チェーン破断防止)
- NFR-306 / NFR-602c / NFR-604 の日次再計算でハッシュチェーン連続性を維持

1.7.5 7.5 監査対象操作の網羅範囲

詳細はメイン側 [10_セキュリティ設計書.md §7.2](#) と運営者側 [権限設計書 §7](#) を参照。

1.7.6 7.6 監査ログエクスポート (§10.5)

用途	キー (HKDF info)	有効期限
監査ログエクスポート署名	info=audit-export(グローバル派生)	ファイル単位
監査ログ R2 アーカイブ署名	info=audit-archive(グローバル派生)	アーカイブ単位

R2 アーカイブ後の再検証: `R2AuditArchiveWorker` が書き出す JSONL の末尾に `chain_summary` 行 (最終 `record_hash` + HMAC-SHA256 署名) を付与。RB-017 で復元時検証手順規定。

1.8 8. 秘密情報管理 (運営者側固有)

メイン側 [10_セキュリティ設計書.md §8](#) を正本とする。運営者側固有:

鍵種別	保管	用途	ローテーション
MFA シークレット	operator_mfa_secrets(AES-256-GCM、オーナー派生)	TOTP 検証	アカウント更新時
MFA 回復コード	operator_mfa_recovery_codes(Argon2id ハッシュ)	MFA 復旧	1回限り使用
4-eyes ペイロード hash	operator_approvals.payload_hash(SHA-256)	改ざん検知	-
内部 API JWT 署名	info=internal-api(グローバル派生)	連携 IF mTLS + JWT	リクエスト毎 (exp 5 分)
MFA セットアップトークン	info=mfa-setup(グローバル派生)	MFA 初回設定	72 時間
再認証セッショントークン	info=re-auth(グローバル派生)	重要操作前再認証	5 分 (1回限り)

1.9 9. SaaS 特有のセキュリティ観点 (運営者側固有)

観点	対策	関連設計書
管理者権限の濫用防止	4-eyes 多段承認 + 監査ログ全件 + ハードゲート KV	09_ 認証認可設計書.md §7 / 本書 §7
監査ログ改ざん防止	ハッシュチェーン + 完全性検証バッチ + tombstone	本書 §7
GDPR 越境移転対応	owner_registration_reviews で EU/EEA/UK 契約を審査 (4-eyes 承認 + 同意書)	§10
削除済み契約の証跡	accounts_retired 永久保持 (スラグのみ)	04_ テーブル定義書.md §3.13
MFA 自己リセット禁止	別運営者承認必須	09_ 認証認可設計書.md §4

1.10 10. 法令対応 (§1.5 から移管)

法令	影響箇所	物理化方針
APPI 30 条 (不適正利用禁止)	監査ログ閲覧自体の記録	audit.search action コード (retention_class='1y') で検索操作を記録
APPI 33 条 (開示請求)	運営者手動対応	inbox_messages で運営者へ通知し手動対応
GDPR 越境移転規制 (46 条)	データリージョン管理	MVP は Cloudflare APAC リージョン固定。EU 顧客の契約登録時は § 10.1 参照
国税通則法・法人税法施行規則	課金エビデンス 7 年保持	audit_logs.retention_class='7y' で識別、billing_invoices は 7 年保持
電子帳簿保存法 (真実性)	取引データ改ざん防止	監査ログハッシュチェーン (prev_hash
電子帳簿保存法 (可視性)	3 検索要件	SCR-096 で billing_invoices の検索 UI 提供 (取引日範囲・金額範囲・contract_owner_user_id 指定)
電子帳簿保存法 (関連書類保存)	取引情報 5 年保持	audit_logs.retention_class='5y'
改正電気通信事業法	外部送信規律	SCR-094 で外部送信先一覧を運営者通知
特定電子メール法	運営者発通知	メール本文末尾に法人名・住所・問合せ先・配信停止 URL 自動付与

1.10.1 10.1 GDPR 越境移転規制への運用ガード (§1.5.1)

EU/EEA/UK 検知時のワークフロー:

- ・ **検知点:** 契約登録フォーム (SCR-002) で「事業所所在地」「主要顧客所在地」必須入力
- ・ **判定基準:** 国コード ISO 3166-1 alpha-2 ホワイトリスト (EU 27 + EEA 3 + UK)
- ・ **動作:**
 - owner_registration_reviews.status='pending_legal_review' に申込情報を保存
 - 運営者 inbox(legal/high) 通知 + メール送信
 - メイン側 SCR-002 完了画面に「審査中」表示
- ・ **4-eyes 承認:** 法務確認書面の事後添付と監査ログ記録を必須
- ・ **同意取得書面:** 「日本データセンター処理同意書」を別途締結、書面 ID のみ audit_logs(owner.legal_review.approve, retention_class='5y') に記録
- ・ **監査ログ:** owner.legal_review.{detect, approve, reject} の 3 action コード (retention_class='5y')
- ・ **Runbook:** RB-023(EU 顧客検知時の対応)

1.11 11. 不正利用検知 (運営者側固有)

メイン側 10_セキュリティ設計書.md §10 を参照。運営者側固有:

- ・ 短時間で複数契約に対する高権限操作 → 運営者通知 (critical)
- ・ 4-eyes 申請の異常パターン (同一申請者から連続) → 運営者通知

1.12 12. 監視 (運用統合)

(運用詳細は 03_運用/運用手順書.md を参照、本書では監視対象のみ)

監視対象	閾値	アクション
監査ログ完全性	差異検出	運営者通知 (critical)+ DB ロック
Webhook DLQ	件数 > 10	運営者通知 (high)
MFA 失敗率	5% / 5 分	運営者通知 (high)
Stripe Webhook 受信失敗率	> 5% / 1h	運営者通知 (high、NFR-808)
月次請求確定 cron 失敗	3 回連続	運営者通知 (high、FR-303)

1.13 13. 脆弱性対応 SLA・SCA・ペネトレーション (§10.10)

項目	仕様
脆弱性対応 SLA(NFR-330)	Critical(CVSS 9.0+ / 悪用観測あり)= 24h、High(7.0~8.9)= 7d、Medium(4.0~6.9)= 30d、Low(<4.0)= 次定例リリース
SLA 超過対応	運営者ダッシュボード (SCR-090 系) で可視化
SCA(NFR-331)	npm audit / Dependabot / Trivy 等を CI に必須組込、週次フルスキャン
Critical 検出時	NFR-330 の SLA に従い対応開始、未対応 Critical でのリリースをブロック
ペネトレーションテスト (NFR-332)	年 1 回以上 + 重大機能変更時 (認証・認可・課金・運営者操作・AI 推論基盤の変更)
実施記録	範囲・実施日・発見項目・対応状況を 5 年間保持 (audit_logs(retention_class='5y'))

1.14 14. ウィジェット保護 / PII マスキング / プロンプト注入対策

メイン側 [10_セキュリティ設計書.md §12~13](#) を正本とし、運営者側からは参照のみ。

PII 3 層検出の運用詳細 (運営者側固有):

- 第 1 層 (正規表現): <5ms、既知パターン再現率 100%(国内携帯 / 固定電話・主要メール形式・JCB / VISA / Master / AMEX(Luhn 検証)・マイナンバー (チェックデジット)・7 桁郵便番号・IPv4/IPv6)
- 第 3 層 (FAQ 整合性検査): <50ms、参照 FAQ 外固有名詞・数値・手順の検出再現率 ☑ 95% / 適合率 ☑ 90%
- マスキング形式: [情報型](例: [電話番号])
- 誤検出救済フロー: 報告 → 運営者 3 営業日判定 → KV ルール更新 (KV キー: pii-rules:regex / pii-rules:classifier、TTL 60s)
- 過去データは修正しない (今後の検出のみ適用、FR-064(d))

プロンプト注入対策の運用詳細 (運営者側固有):

- 回帰テストセット保守: FR-063、20 ケース以上、四半期更新
- 攻撃パターン: 役割再定義 / タグ脱出 / コード注入 / 言語切替誘導 / 指示上書き / ロール変更要求 / システムプロンプト開示要求 / 参照 FAQ 外の事実回答誘導 / 機密情報抽出誘導
- 実行タイミング: AI モデル変更時 / プロンプトテンプレート変更時 / 四半期定期
- データセット管理者: 運営者 (SCR-092 系で管理 UI 提供)

1.15 15. Webhook 比較除外フィールド (付録 H、D-06)

Stripe Webhook ペイロード正規化 JSON ハッシュ計算で **除外する** 非決定的フィールド:

フィールドパス	理由
\$.created	イベント生成タイムスタンプ (再送で変動)
\$.request.id	Stripe 内部リクエスト ID (再送で変動)
\$.request.idempotency_key	Stripe 側の冪等性キー再発行ありえる
\$.livemode	テストモード / 本番モードでの値差分
\$.data.object.created	リソース作成時刻 (API 仕様変更耐性のため除外)
\$.data.object.metadata.stripe_request_id	Stripe 内部メタデータ
\$.data.object.latest_charge.id (該当時)	同一イベント内派生リソース ID
\$.api_version	Stripe API バージョン (再送時に最新バージョンへ昇格の可能性)

正規化方式:

- 上記フィールドを削除
- JSON のキーを再帰的にアルファベット昇順ソート
- 空白文字をすべて除去 (\s+ 完全削除、文字列値内は保持)
- UTF-8 バイト列に対し SHA-256 を計算

詳細実装は [04_テーブル定義書.md §3.9 webhook_payload_diffs](#) 参照。

1.16 16. バックアップ・復旧

メイン側 [10_セキュリティ設計書.md §14](#) を参照。

1.17 17. 未決事項

(該当なし)

1.18 18. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude